

# ENGINEERING-GRADE REPRODUCTION, HEURISTIC DETECTION CASCADE, AND ADVERSARIAL SIMULATION OF PAYLOAD-BASED TRANSACTION PHISHING (PTXPHISH) ON ETHEREUM

Student Researcher: Adityaraj Shyamsundar Bhandari | Roll No: 2024UCP1639

Institution: Malaviya National Institute of Technology (MNIT), Jaipur (B.Tech Computer Science & Engineering, CGPA: 8.48)

## 1. Abstract & Executive Summary

With the rapid maturation of Decentralized Finance (DeFi) on Ethereum, threat actors have evolved beyond rudimentary frontend credential phishing into sophisticated **Payload-Based Transaction Phishing (PTXPhish)**. Unlike traditional scams where victims visit fraudulent landing pages or approve direct token transfers, PTXPhish tricks users into interacting with entirely legitimate, trusted smart contract protocols (such as Uniswap, Blur, or OpenSea). Behind the scenes, maliciously crafted calldata parameters secretly subvert transaction semantics—such as setting marketplace fee parameters to 100% or executing zero-value address poisoning.

This project presents an exhaustive engineering-grade reproduction and extension of the NDSS 2025 foundational study. We establish a multi-tier deterministic heuristic detection engine achieving an overall accuracy of **97.60%** and a Macro F1-score of **0.976** across a balanced benchmark of N=500 transactions. Furthermore, to satisfy rigorous academic review criteria requiring an 'attack-like' perspective, we developed an **Adversarial Payload Synthesizer (attacker\_simulator.py)** that programmatically models how threat actors construct malicious EVM calldata. All findings are packaged into a production-grade Streamlit web application (app.py) featuring live archive node inspection and automated on-chain alert dispatching.

## 2. Introduction, Background, & Research Rationale

**2.1 The Evolution of Web3 Threat Vectors:** The Ethereum blockchain operates via state-transition transactions initiated by Externally Owned Accounts (EOAs) interacting with Contract Accounts (CAs). Early blockchain security research focused primarily on phishing landing pages, fake wallet extensions, and simple direct-transfer fraud. However, as users grew accustomed to verifying contract addresses and interacting with decentralized applications (dApps), scammers adapted by moving the deception directly into the transaction calldata layer.

**2.2 Why We Chose This Research Topic:** We selected PTXPhish as our core research focus because it represents a profound paradigm shift in cybercrime: the victim signs a transaction targeting a reputable, verified contract address, believing the operation is safe, while internal parameter manipulation executes asset expropriation. Investigating this threat allows us to bridge theoretical smart contract security with deployable defensive systems.

**2.3 Scope and Research Contributions:** This research bridges the gap between static dataset analysis and real-time defensive operations by: (1) Re-implementing the NDSS 2025 detection taxonomy into a high-performance Python application; (2) Engineering a live Web3 archive node querying engine via Web3.py; (3) Building an offensive payload simulation module; and (4) Establishing a robust empirical evaluation framework.

## 3. Threat Model & Taxonomy of PTXPhish

Based on the foundational taxonomy established by Chen et al., PTXPhish is categorized into two primary strategies comprising eleven distinct sub-categories:

- Strategy I: Abusing Legitimate Contracts:** Includes *Ice Phishing* (approval hijacking via ``approve`` or ``setApprovalForAll``), *Permit2 / Off-Chain Signature Exploitation* (forging EIP-712 permits), and *NFT Marketplace Order Hijacking* (manipulating fee recipients to 100%).
- Strategy II: Exploiting Phishing Contracts:** Includes *Address Poisoning* (zero-value dust transfers using vanity address generation) and *Payable Function Scams* (malicious fallback execution).

Understanding these threat vectors requires analyzing low-level EVM bytecode execution paths, function signature collisions, and parameter encoding formats. Attackers rely heavily on social engineering combined with strict adherence to standard interface ABIs (Application Binary Interfaces) so that wallet extension popups appear entirely standard to unsuspecting users.

## 4. Comparative Analysis: Original NDSS 2025 Model vs. Our Implementation

While the original research was structured as an offline macro-scale measurement study over 300 days across historical blocks, our project transforms their theoretical taxonomy into an interactive, production-grade security framework. Our implementation introduces sub-second archive node RPC querying, a 4-tier deterministic heuristic cascade, an offensive payload synthesizer, and 1-click remediation routing.

**Core Architecture Shift:** Whereas the original researchers utilized batch SQL queries and offline Python notebooks to mine historical blockchain dumps, our system operates as an event-driven edge inspector capable of evaluating arbitrary transaction hashes submitted by users or evaluators in real time.

## 5. Dataset Construction & Empirical Ground-Truth Methodology

To evaluate our heuristic engine, we constructed a balanced benchmark dataset comprising **N = 500 transactions** (125 samples across each primary threat class: Ice Phishing, NFT Order Phishing, Address Poisoning, and Benign/Payable interactions). Data collection combined public

phishing complaints, security community disclosures, and historical transaction expansions derived from known scammer addresses.

Each transaction record underwent rigorous manual verification against Etherscan transaction receipts, internal trace logs, and state change diffs to establish an unassailable ground-truth label set for quantitative validation.

## 6. Architecture of the 4-Tier Deterministic Heuristic Detection Cascade

Our detection engine processes raw transaction input payloads (`tx['input']`) and native value (`tx['value']`) through a high-performance 4-tier rule cascade:

- **Tier 1 (NFT Marketplace Order Validation):** Inspects function selectors (`0x1255f005`, `0xfb0f3ee1`, `0x539564c7`) and parameter fee distributions.
- **Tier 2 (Address Poisoning Filter):** Cross-references zero-value transfers against known vanity address prefix/suffix heuristics.
- **Tier 3 (Ice Phishing Detector):** Intercepts approval selectors (`0x095ea7b3`, `0xa22cb465`, `0x39509351`) targeting unverified spenders.
- **Tier 4 (Payable Fallback Trap Analyzer):** Evaluates native ETH value transfers coupled with unverified contract interactions.

## 7. Offensive Security Module: Adversarial Payload Synthesizer

To satisfy evaluator requirements for an offensive research perspective, we engineered `attacker_simulator.py`. This module programmatically takes a function selector and threat category, then maps low-level hex to exploit archetypes, generates step-by-step payload construction narratives, and profiles victim asset exposure severity.

By demonstrating how attackers construct calldata parameters, this module provides invaluable dual-sided insight into both offensive threat engineering and defensive signature design.

## 8. Interactive Security Dashboard & Forensic Visualization Engine

The Streamlit web application (`app.py`) serves as a dual-purpose **Attack & Defense Visualizer**. It connects to a multi-RPC failover pool (`Web3.py`) to inspect any transaction hash (`0x...`) sub-second. It displays classification verdicts, risk levels, and the Adversarial Attack Anatomy panel simultaneously, allowing evaluators to interact directly with the detection pipeline.

## 9. Quantitative Performance Evaluation & Accuracy Analysis

Tested on our N=500 balanced benchmark, the system achieved an overall accuracy of **97.60%** and a Macro F1-score of **0.976**.

| Evaluation Metric     | Score / Performance | Benchmark Scope              |
|-----------------------|---------------------|------------------------------|
| Overall Accuracy      | 97.60%              | N = 500 Balanced Test Set    |
| Macro F1-Score        | 0.976               | Multi-Class Weighted Average |
| NFT Order Phishing F1 | 1.00                | Deterministic Selector Match |
| Address Poisoning F1  | 0.96                | Zero-Value Heuristic Filter  |

**Error Rationale (2.40% Margin / 12 misclassifications):** Caused by polymorphic proxy routing obscuring function selectors, zero-value benign interacting overlapping with address poisoning, and dynamic parameter padding mutations by advanced threat actors.

## 10. Active Remediation Protocol & Conclusion

**10.1 Active Remediation:** Implements Section VIII of NDSS by generating 0-ETH rescue transactions carrying UTF-8 warning advisories, alongside 1-click deep-linking to `Revoke.cash` for immediate allowance revocation.

**10.2 Conclusion:** This work successfully operationalizes the findings of NDSS 2025 PTXPhish into an interactive, rigorous security analysis framework, uniting sub-second archive inspection, deterministic classification, and adversarial simulation to deliver a complete defensive and offensive research solution.